

1. What is SY0-701 and why is it important?

SY0-701 This is the current exam code for the CompTIA Security+ certification, officially launched on [date]. **7/11/2023** And it is the only version that will remain active until the end of 2026. The older SY0-601 version was retired on July 31, 2024 — if your study materials still say “SY0-601”, discard them immediately as they are outdated.

Security+ is the world's most popular cybersecurity entry-level certification, with over 700,000 holders. In Vietnam, this certification is explicitly listed in job descriptions for most entry-level SOC Analyst, Junior Security Engineer, and IT Security positions at banks and multinational corporations.

Prerequisites before starting

Minimum knowledge requirements:

- Understand the 7-layer OSI model (or the 4-layer TCP/IP model).
- Biết subnet, IP public vs private, NAT, DHCP, DNS
- Familiar with Windows and Linux CLI (cd, ls, ping, ipconfig, ifconfig)
- Understand the concepts of file system, process, and service.
- English Reading Comprehension Level B1-B2 (English Exam)

Required hardware:

- Laptop/PC with 8GB or more of RAM (16GB is ideal for running VMs)
- 100GB of free hard drive space
- Stable internet connection
- Headphones with a microphone (provided if taking the exam at home)



2. Exam format

Here are some parameters you need to know:

Parameter	Value
Exam code	SY0-701
Maximum number of sentences	90 sentences
Time	90 minutes
Parking point	750/900 (approximately 83%)
Question type	Multiple choice + Performance-Based Questions (PBQ)
Language	English, Japanese, German, Thai, Spanish, Portuguese
Voucher price	425 USD (US price — usually lower in Vietnam through partners)
Validity	3 years (renewable via CE)
Input requirements	Not required (Network+ and 2 years of IT Security experience are recommended)

Special scoring formula: CompTIA uses a 100-900 point scale. Each question has a different weighting — PBQ generally takes a heavier weight than multiple choice. No

points are deducted for incorrect answers, so **Always choose one answer** Even if it's uncertain.

3. Detailed analysis of 5 domains

This is the score map for SY0-701 — to use as a basis for allocating study time:

Domain 1 — General Security Concepts (12%)

Fundamental content on cybersecurity:

- **CIA Triad**(Confidentiality, Integrity, Availability) and extended models such as AAA (Authentication, Authorization, Accounting)
- **Classification of Security Controls:** preventive, detective, corrective, compensating, deterrent, directive
- **Classification by nature:** technical, managerial, operational, physical
- **Basic cryptographic concepts:** symmetric vs asymmetric, hashing, digital signature, PKI, certificate, key management
- **Change management process** in a business environment
- **Zero Trust** architectural model — the concept of "trust nothing, verify everything"

Difficulty level: Easy to remember but easy to confuse the different types of controls. Learn using flashcards.

Domain 2 — Threats, Vulnerabilities, and Mitigations (22%)

The second largest domain, focusing on identification and response:

- **Threat actors:** nation-state, organized crime, hacktivist, insider threat, unskilled attacker
- **Attack vectors:** message-based (phishing, smishing, vishing), image-based, file-based, supply chain, removable device
- **Malware types:** ransomware, trojan, worm, rootkit, keylogger, spyware, bloatware
- **Application attacks:** injection (SQLi, LDAP, XML), buffer overflow, race condition, privilege escalation
- **Network attacks:** DDoS, DNS poisoning, on-path (MITM), wireless attacks, credential replay
- **Cryptographic attacks:** birthday, collision, downgrade

- **Password attacks:** spraying, brute force, dictionary, rainbow table
- **Mitigation techniques:** segmentation, access control, isolation, patching, encryption, monitoring

Difficulty level: Average. It's important to remember the precise concepts and differentiate between variants (smishing vs. vishing, rootkit vs. trojan).

Domain 3 — Security Architecture (18%)

Architecture and design of safety systems:

- **Architecture models:** on-premises, cloud (IaaS/PaaS/SaaS), hybrid, centralized vs decentralized
- **Infrastructure considerations:** high availability, scalability, resilience
- **Network architecture:** DMZ, screened subnet, VLAN, VPN (IPsec, SSL/TLS, L2TP), SD-WAN, SASE
- **Firewall types:** WAF, NGFW, UTM, stateful vs stateless
- **Security components:** IDS/IPS, DLP, NAC, load balancer, proxy, jump server
- **Data protection:** at rest, in transit, in use; tokenization, masking, obfuscation
- **Data classification:** sensitive, confidential, public, restricted, PII, PHI

Difficulty level: Systems thinking is needed. PBQ often appears here — requiring the firewall, IDS, and load balancer to be placed in the correct positions within the diagram.

Domain 4 — Security Operations (28%) - Largest Domain

This is the domain with the highest weight — invest time in studying this domain thoroughly for a higher chance of passing.

- **Baseline & hardening** cho server, endpoint, wireless, mobile
- **Asset management lifecycle:** acquisition, assignment, monitoring, disposal
- **Vulnerability management:** scan, analysis, remediation, validation, reporting; CVSS scoring; CVE; common scan tools
- **Alerting & monitoring:** SIEM, SCAP, NetFlow, SNMP, log aggregation

- **Incident response lifecycle:** preparation → detection → analysis → containment → eradication → recovery → lessons learned (theo NIST SP 800-61)
- **Digital forensics:** chain of custody, order of volatility, imaging, data acquisition
- **Identity & Access Management:** provisioning, de-provisioning, MFA, SSO, federation, IAM solutions (SAML, OpenID, OAuth)
- **Automation & orchestration:** SOAR, script basics, API integration

Difficulty level: This was the most difficult part of the whole exam. There were so many terms and procedures to remember.

Domain 5 — Security Program Management and Oversight (20%)

Governance, Risk, and Compliance (GRC):

- **Risk management:** identification, assessment (qualitative vs quantitative), appetite, tolerance
- **Risk treatment:** transfer, accept, avoid, mitigate
- **Third-party risk & vendor management:** due diligence, supply chain, SLA, MOU, MSA, NDA
- **Governance structures:** board, committee, policy, procedure, standard, guideline
- **Compliance:** regulations (GDPR, HIPAA, PCI DSS, SOX), internal/external audit, attestation
- **Security awareness:** phishing training, recognition, reporting
- **Business continuity:** BIA, BCP, DRP, RTO, RPO, MTTR

Difficulty level: Multiple legal definitions. Tip: match the term with an image or a real-life case.

4. Performance-Based Questions (PBQ) — the biggest difference

PBQ is a type of question that simulates real-life situations; it's not a multiple-choice (A/B/C/D) question, but rather asks you to answer a question.**operation**On the simulated interface. Typically, 4-6 PBQs appear per test, with heavy scoring (each PBQ can be equivalent to 5-10 multiple-choice questions).

Common types of PBQ:

- **Drag-and-drop firewall rule**— Match the rule with the correct order of priority
- **Matching**— Match attack with appropriate mitigation
- **Network diagram placement**— Install the IDS, firewall, and DMZ in the correct locations.
- **Log analysis**— Read Windows Event/Syslog logs and identify the attack type.
- **Command output interpretation**— Read the output of nmap, netstat, and tcpdump and make inferences.
- **Configuration**— Select the correct settings for WPA3, VPN, and TLS

BBQ strategy:

1. PBQ appears at the beginning of the article.**Mark for review and skip**Right now, do the multiple-choice questions first to secure your score.
2. Return to the BBQ when there are about 30-40 minutes left.
3. If you're not sure,**Fill in the most appropriate answer**.and move on to the next sentence — it cannot be left blank because 1 PBQ = multiple sentences.
4. When practicing, use**CompTIA CertMaster Labs**Or use the TryHackMe/HackTheBox platform to familiarize yourself with the interface.

5. What are the differences between SY0-701 and SY0-601?

If you've ever taken SY0-601, here are the important changes you need to be aware of:

Change	SY0-601	SY0-701
Domain number	6	5 (gộp Implementation vào Architecture & Operations)
Security Operations weighting	16%	28% (increased sharply)

Zero Trust	Basic	In-depth , many questions
AI threats	Do not have	Add new (prompt injection, deepfake)
Supply chain	Light	Extend (SolarWinds-style attack)
Hybrid cloud	Have	Strengthen
SOAR & automation	Rarely mentioned	Emphasize
Cryptography theory	Heavy	Reduce , focusing on application

Meaning: SY0-701 leans towards **actual operation**. Furthermore, there are significantly more questions about SOC, IR, and threat hunting scenarios. If you have studied SY0-601, you need to supplement your knowledge with AI threat, Zero Trust, SOAR, and hybrid cloud.